

Marco Integrativo GQM + PRAGMATIC para Indicadores SASE

Marco conceptual para enlazar objetivos nacionales (ENS, NIS2, Estrategia Nacional de Ciberseguridad) con métricas técnicas SASE mediante GQM (Goal–Question–Metric) y evaluar la calidad de cada métrica con el metamodelo PRAGMATIC (Predictive, Relevant, Actionable, Genuine, Meaningful, Accurate, Timely, Independent, Cheap).

1. Introducción

La arquitectura SASE aporta un plano técnico unificado (red + seguridad) ideal para instrumentar métricas alineadas con objetivos de política pública y de negocio. El riesgo habitual es empezar por la métrica (“latencia”, “MTTR”, “MFA”) sin tener claro el **para qué** y el **qué decisión** soporta.

El enfoque GQM obliga a partir de objetivos explícitos, formular preguntas diagnósticas y solo después definir métricas, mientras que PRAGMATIC proporciona un checklist sistemático para decidir si una métrica merece un lugar en el cuadro de mando.

2. Resumen de los marcos GQM y PRAGMATIC

2.1. GQM (Goal–Question–Metric)

- Goal (Objetivo)
Propósito de la medición, objeto a medir, punto de vista, contexto.
- Question (Pregunta)
Preguntas que aclaran si el objetivo se está logrando o no.
- Metric (Métrica)
Medidas cuantitativas/ cualitativas que permiten responder las preguntas.

Esquema mínimo de definición de un objetivo GQM:

Analizar <objeto> con el propósito de <motivo> desde el punto de vista de <rol> en el contexto de <organización/entorno>.

2.2. PRAGMATIC

Cada métrica se valora (por ejemplo, de 0 a 3 o de 1 a 5) según:

- P – Predictive (Predictiva)
¿Anticipa problemas u oportunidades futuros?
- R – Relevant (Relevante)
¿Importa de verdad al objetivo y a los decisores?
- A – Actionable (Accionable)
¿Sugiere acciones concretas? ¿Qué harías si empeora?
- G – Genuine (Genuina)
¿Mide lo que dice medir, sin ser un proxy engañoso?
- M – Meaningful (Significativa)
¿Se entiende fácilmente, sin tesis doctoral?
- A – Accurate (Precisa)
¿Es suficientemente exacta para la decisión a tomar?
- T – Timely (Oportuna)
¿Está disponible cuando hace falta decidir?
- I – Independent (Independiente)
¿Está poco contaminada por conflictos de interés / manipulaciones?
- C – Cheap (Rentable)
¿Su coste de obtención y mantenimiento compensa el valor que aporta?

3. Objetivos nacionales y de alto nivel aplicables a SASE

Ejemplos de objetivos (G) que sirven de raíz GQM para el marco SASE:

1.
Garantizar la continuidad y disponibilidad de los servicios esenciales digitales.
 - Relacionado con ENS (disponibilidad, continuidad de la actividad) y NIS2 (servicios esenciales).
2.
Reducir de forma mensurable el riesgo de ciberincidentes en acceso remoto y cloud.
 - NIS2 (gestión de riesgos, incidentes), ENS (confidencialidad, integridad, trazabilidad).
3.
Mejorar la experiencia de usuario (QoE) en servicios digitales críticos, manteniendo controles de seguridad proporcionales.
 - Objetivos de administración digital y confianza en servicios.
4.
Asegurar el cumplimiento efectivo de ENS y NIS2 en entornos híbridos y multicloud.
 - Alineamiento regulatorio y auditorías.
5.
Optimizar el uso de recursos mediante consolidación de plataformas de red y seguridad, demostrando un ROI razonable.
 - Objetivos de eficiencia y sostenibilidad presupuestaria.

Garantizar la continuidad y disponibilidad de los servicios esenciales digitales.

- Relacionado con ENS (disponibilidad, continuidad de la actividad) y NIS2 (servicios esenciales).

Reducir de forma mensurable el riesgo de ciberincidentes en acceso remoto y cloud.

- NIS2 (gestión de riesgos, incidentes), ENS (confidencialidad, integridad, trazabilidad).

Mejorar la experiencia de usuario (QoE) en servicios digitales críticos, manteniendo controles de seguridad proporcionales.

- Objetivos de administración digital y confianza en servicios.

Asegurar el cumplimiento efectivo de ENS y NIS2 en entornos híbridos y multicloud.

- Alineamiento regulatorio y auditorías.

Optimizar el uso de recursos mediante consolidación de plataformas de red y seguridad, demostrando un ROI razonable.

- Objetivos de eficiencia y sostenibilidad presupuestaria.

4. Aplicación GQM a indicadores clave SASE del informe

En esta sección se resume la estructura GQM para los principales grupos de indicadores del informe SASE previo. El detalle exhaustivo de cada métrica se desarrolla en la matriz PRAGMATIC.

4.1. Grupo 1 – Latencia, jitter, pérdida y QoE SASE

Goal G1.

Analizar el rendimiento extremo a extremo del acceso a servicios cloud y aplicaciones internas críticas, con el propósito de garantizar una experiencia de usuario adecuada y la continuidad de servicios esenciales, desde el punto de vista de responsables de servicio y ciberseguridad, en el contexto de la administración digital y operadores sujetos a ENS/NIS2.

Questions Q1.x:

- Q1.1: ¿Cuál es la latencia típica y de cola (p95/p99) hacia las aplicaciones críticas a través de SASE?
- Q1.2: ¿Qué jitter y pérdida de paquetes se registran para tráfico sensible (voz, vídeo, aplicaciones transaccionales)?
- Q1.3: ¿Cuál es el tiempo de transacción (p.ej. carga de página, operación clínica, registro educativo) visto desde el usuario?
- Q1.4: ¿Qué disponibilidad efectiva tienen los PoPs/ túneles SASE que soportan servicios esenciales?
- Q1.5: ¿Cómo se traduce todo lo anterior en un índice de QoE comprensible para negocio?

Metrics M1.x:

- M1.1: Latencia media y p95/p99 hacia aplicaciones críticas (ms).
- M1.2: Jitter medio y p95 en tráfico de voz/vídeo (ms).
- M1.3: Pérdida de paquetes (%) en enlaces/túneles relevantes.
- M1.4: Tiempo medio de carga de página/operación en aplicación clave (s).
- M1.5: Disponibilidad mensual de PoPs/túneles SASE (%).
- M1.6: Índice compuesto de QoE (0–100) por tipo de servicio/sector.

4.2. Grupo 2 – Métricas de Zero Trust, identidad y ZTNA

Goal G2.

Analizar el grado de implantación de principios Zero Trust en el acceso a recursos internos y cloud, con el propósito de reducir la superficie de ataque y el movimiento lateral, desde el punto de vista de CISOs y arquitectos de seguridad, en organizaciones sujetas a ENS/NIS2.

Questions Q2.x:

- Q2.1: ¿Qué porcentaje de usuarios sensibles utiliza MFA y políticas contextuales?
- Q2.2: ¿Qué proporción de aplicaciones internas críticas se expone únicamente vía ZTNA?
- Q2.3: ¿En qué medida la segmentación se basa en identidad/rol en lugar de en red plana?
- Q2.4: ¿Existe un roadmap Zero Trust formal y se monitoriza su avance?

Metrics M2.x:

- M2.1: % de cuentas con MFA activo sobre universo de usuarios sensibles.
- M2.2: % de aplicaciones críticas accesibles solo vía ZTNA.
- M2.3: Porcentaje de accesos privilegiados gestionados mediante ZTNA + políticas contextuales.
- M2.4: Índice de madurez Zero Trust (escala 0–100) basado en un modelo de niveles.

4.3. Grupo 3 – Métricas SOC: MTTD, MTTR, MTTC en SASE

Goal G3.

Analizar la eficacia de detección y respuesta a incidentes relacionados con el plano SASE (acceso remoto y cloud), con el propósito de reducir el impacto de incidentes y el tiempo de exposición, desde el punto de vista del SOC nacional o corporativo.

Questions Q3.x:

- Q3.1: ¿Cuánto tiempo se tarda de media en detectar incidentes relacionados con SASE?
- Q3.2: ¿Cuánto se tarda en contenerlos (bloqueo de usuario, política, túnel)?
- Q3.3: ¿Cómo se compara el rendimiento actual con la línea base pre-SASE?
- Q3.4: ¿Qué volumen y tipo de amenazas bloquea el plano SASE?

Metrics M3.x:

- M3.1: MTTD-SASE (Mean Time To Detect) en minutos/horas.
- M3.2: MTTC-SASE (Mean Time To Contain).
- M3.3: MTTR-SASE (Mean Time To Recover).
- M3.4: Número de incidentes SASE al mes y su distribución por severidad.
- M3.5: Número de amenazas bloqueadas por categoría (malware, phishing, C2, exfiltración).

4.4. Grupo 4 – Cumplimiento ENS/NIS2 y gobierno

Goal G4.

Analizar hasta qué punto SASE se utiliza como plano común para implantar medidas ENS y NIS2 en servicios cloud y acceso remoto, con el propósito de mejorar el cumplimiento y la auditabilidad de los controles, desde el punto de vista de responsables de cumplimiento y auditores.

Questions Q4.x:

- Q4.1: ¿Qué porcentaje de proyectos cloud integra de forma sistemática SASE/ZTNA?
- Q4.2: ¿Hasta qué nivel existe mapeo formal SASE–ENS/NIS2?
- Q4.3: ¿Qué proporción de acceso a sistemas ENS medio/alto pasa por SASE?
- Q4.4: ¿Qué nivel de integración de telemetría SASE hay en el ecosistema de auditoría/SIEM?

Metrics M4.x:

- M4.1: % de proyectos cloud con integración obligatoria en SASE.
- M4.2: % de sistemas ENS medio/alto cuyo acceso remoto se canaliza vía SASE/ZTNA.
- M4.3: % de logs de acceso cloud/privado que provienen de la plataforma SASE.
- M4.4: Índice de alineamiento SASE–ENS/NIS2 (basado en checklist de controles).

4.5. Grupo 5 – Continuidad de negocio y resiliencia SASE

Goal G5.

Analizar la contribución de SASE a la continuidad de negocio y resiliencia de servicios críticos, con el propósito de limitar interrupciones y degradaciones, desde el punto de vista de responsables de continuidad y riesgo operativo.

Questions Q5.x:

- Q5.1: ¿En qué medida SASE está incorporado en planes de continuidad?
- Q5.2: ¿Qué nivel de redundancia (PoPs, enlaces, proveedores) existe en la arquitectura SASE?
- Q5.3: ¿Qué tiempos de indisponibilidad se observan cuando falla un PoP/enlace?

Metrics M5.x:

- M5.1: % de planes de continuidad donde SASE aparece explícitamente como activo/mitigador.
- M5.2: Número medio de rutas alternativas por sede/servicio crítico.
- M5.3: Tiempo medio de conmutación a PoP/enlace alternativo (s/min).
- M5.4: Tiempo de indisponibilidad anual atribuible a fallos en SASE.

4.6. Grupo 6 – Negocio, consolidación y ROI

Goal G6.

Analizar el valor de negocio de SASE en términos de consolidación de herramientas, reducción de costes y coste evitado, con el propósito de justificar inversiones y priorizar iniciativas, desde el punto de vista de dirección y finanzas.

Questions Q6.x:

- Q6.1: ¿Qué grado de consolidación de proveedores y plataformas se ha logrado con SASE?
- Q6.2: ¿Qué ahorros de licencias infra y OPEX se han obtenido?
- Q6.3: ¿Qué reducción de incidentes y tiempo de inactividad se puede asociar a SASE?
- Q6.4: ¿Cuál es el ROI global, considerando costes y beneficios anuales?

Metrics M6.x:

- M6.1: Número de plataformas de red/seguridad sustituidas por SASE.
- M6.2: Ahorro anual en licencias y contratos heredados (€).
- M6.3: Reducción de horas de operación / soporte por año.
- M6.4: Reducción de incidentes mayores atribuibles al cambio de arquitectura.
- M6.5: ROI SASE (%) calculado sobre horizonte de 3–5 años.

5. Cómo se combinan GQM y PRAGMATIC en este marco

6. Partir de objetivos Gx claros, vinculados a ENS/NIS2 y estrategias nacionales.
7. Derivar preguntas Qx,y que obliguen a aclarar el “cómo sabremos si vamos bien”.
8. Definir métricas Mx,y con semántica, unidad, fuente, frecuencia y responsable claros.
9. Puntuar cada métrica con PRAGMATIC, descartando las que, pese a ser fáciles de obtener, apenas son predictivas, relevantes o accionables.
10. Priorizar aquellas métricas con mejor puntuación PRAGMATIC como candidatas al cuadro de mando nacional o sectorial.

En los documentos complementarios se desarrolla una matriz detallada con la puntuación PRAGMATIC de cada métrica y ejemplos de uso.